

1. TERMINOLOGY CLARIFICATIONS

Clarifying some key words and terms related to the PCI-DSS, that will be used in the course.



FUNDAMENTALS

FUNDAMENTALS TERMINOLOGY CLARIFICATIONS

The PCI-DSS uses certain abbreviations and terms that are important to clarify before moving further. These can be related to data, networks, systems, and other elements.

Key terms in the PCI-DSS documentation include:

- The CDE, or Card Data Environment. This is the set of networks and systems where cardholder data (CHD) is stored or transmitted, as opposed to the non-CDE.
 - For example, you have 2 WiFi networks. Only one is used for payments. That one is in the CDE. The other isn't;
- Then, we have credit card data. These include account numbers, expiration dates, and more;
 - These must be secured in both storage and in transit;

FUNDAMENTALS

TERMINOLOGY CLARIFICATIONS

Going further, let's clarify which card data can be stored.

- There are usually two categories of data: CHD and SAD.

CHD (Cardholder Data) are usually on the front of the card:

- The full card number (known as the PAN, or Personal Account Number);
- The expiration date;
- The cardholder name, tier, other elements;
- CHD can be stored, with several security controls;

SAD (Sensitive Authentication Data) are usually on the back:

- The 3-digit verification code (CVV, CVV2, etc);
- The magnetic stripe, or the PIN/PIN block;
- SAD cannot be stored at all under the PCI-DSS;





FUNDAMENTALS

FUNDAMENTALS TERMINOLOGY CLARIFICATIONS

The PCI-DSS set of directives includes 6 goals and 12 requirements. Each goal is usually associated with one or more requirements. For example, as of v.4.0.0:

- Goal: Build and Maintain a Secure Network and Systems
 - Req. 1: Install and Maintain Network Security Controls;
 - Req 2: Apply Secure Configurations to All System Components;

While goals are more generic, about the principles, the requirements are more technical and explicit, with specific rules to be implemented.

- In many cases, organizations simply follow the requirements as a checklist (not necessarily the best approach);
- Each requirement should be seen as part of its goal;

FUNDAMENTALS

TERMINOLOGY CLARIFICATIONS

Then, in terms of compliance, in order to comply with PCI-DSS, merchants usually have two mechanisms:

- A Report on Compliance (ROC);
- A Self-Assessment Questionnaire (SAQ) (9 types in total);

Whether a merchant is forced to perform an ROC or not depends on whether they are a Level 1 Merchant (>6M transactions per year);

- They, then, receive an AOC (Attestation of Compliance);

ROCs are usually performed by QSAs, or Qualified Security Assessors - independent, certified security auditors:

- Besides performing full ROCs, these can also help a company select the type of SAQ they must fill.



FUNDAMENTALS

TERMINOLOGY CLARIFICATIONS

EXAMPLES

/01 THE RIGHT SAQ

There are 9 different types of SAQ, depending on how the company handles CHD. Storing, transmitting, card present, card not present, etc.

/02 INDUSTRY COMPLIANCE

PCI-DSS is a type of compliance that is not legally required, but demanded by the merchant's acquiring bank. Failing it can still cause grave penalties, though.

/03 REDUCING THE CDE SCOPE

The CDE, or Card Data Environment, should be reduced as much as possible. The less systems/networks handle CHD, the smaller the scope.

FUNDAMENTALS

TERMINOLOGY CLARIFICATIONS

KEY TAKEAWAYS

/01 CDE AND NON-CDE

The set of systems and networks that CHD passes through is known as the Card Data Environment (CDE). The rest is the non-CDE.

/03 GOALS AND REQUIREMENTS

PCI-DSS has 6 goals and 12 requirements. While the goals are more general, representing principles, the requirements are declarative and specific by nature.

/02 CHD VS. SAD

Card data can be CHD or SAD. Data on the front of a card are known as CHD, including the full number (PAN). Data on the back are the SAD (cannot store).

/04 ROC VS SAQ

Merchants can either go through a Report on Compliance (ROC), if they are Level 1, or a Self-Assessment Questionnaire (SAC) to comply.